

1. ISO 27001 / ISO 27000 Series – Information Security Management Policy

Policy Number: ISM-001

Effective Date: [Insert Date]

Next Review Date: [Insert Date]

Approved by: [Name/Title]

1. Purpose:

The purpose of this policy is to protect the confidentiality, integrity, and availability of sensitive child, family, and donor data managed by World Vision Lanka, ensuring compliance with ISO 27001 standards.

2. Scope:

This policy applies to:

- All employees, volunteers, contractors, and third-party service providers.
- All organizational data, IT systems, and communication channels.

3. Definitions:

- **Information Security:** Protecting information from unauthorized access, disclosure, alteration, and destruction.
- **Sensitive Data:** Personal information of children, families, donors, and staff.

4. Responsibilities:

- **IT Department:** Implement technical controls, encryption, access management, and security monitoring.
- **All Staff:** Adhere to security policies, report incidents immediately.
- **Management:** Approve security measures and allocate resources.

5. Procedures & Key Elements:

- **Risk Assessment:** Conduct regular risk assessments to identify threats and vulnerabilities.
- **Security Controls:** Implement appropriate safeguards including firewalls, antivirus, and intrusion detection.

- **Data Encryption:** All sensitive data must be encrypted at rest and in transit.
- **Access Control:** Role-based access and multi-factor authentication required.
- **Incident Response:** Documented procedures for reporting, investigating, and mitigating security incidents.

6. Compliance & Monitoring:

- Internal and external audits at least once a year.
- Security awareness training for all staff.
- Continuous monitoring of IT infrastructure.

7. References:

- ISO 27001:2022 Standard
- NIST Cybersecurity Framework

8. Review & Approval:

Reviewed annually by the IT Security Committee.